

Normativa de Seguridad

Tema 2

Introducción al cumplimiento normativo

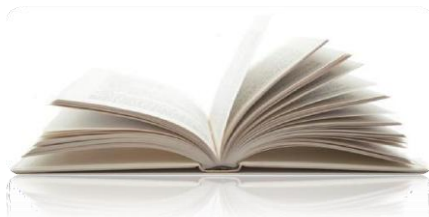
Contenidos

- **Introducción al cumplimiento normativo.**
- Compliance: objetivo, definición y conceptos principales.
- Principios del buen gobierno y ética empresarial
- Compliance Officer: funciones y responsabilidades
- Relaciones con terceras partes dentro del Compliance
- CISO, competencias y responsabilidades

Introducción al cumplimiento normativo

Bloque 1 Introducción y contexto actual

Bloque 2 Protección de datos - RGPD



Bloque 1 Introducción y contexto actual

1. Tendencias y factores externos.
2. Marco normativo nacional e internacional



1.1 Tendencias y factores externos

- Alta probabilidad de ciberataques y robo o uso fraudulento de datos.
- Transformación Digital, Cloud Computing, IoT o Big Data.
- Tendencia Fast, Cheap & Easy.
- Definición de marcos regulatorios.
- El CISO (Chief Information Security Officer) es trascendental
- La entidad define las atribuciones y el perfil del CISO



1.2 Marco normativo nacional e internacional

- Orienta al CISO en las leyes y normativas
- Depende del modelo organizativo de la empresa
- Marco legislativo y regulatorio en constante evolución

1.2 Marco normativo nacional e internacional

Esquema Nacional de Seguridad (ENS) ✨

- Determina la política de seguridad de la información
- Principios básicos y requisitos mínimos para una protección adecuada.
- Referencia legislativa del responsable de la información.
- Esta obligación afecta a todo el Sector Público, a los sistemas de información clasificada y a las entidades del sector privado que les presten soluciones y servicios para el ejercicio de competencias y potestades administrativas.
- Marco de referencia para establecer una política de seguridad.

1.2 Marco normativo nacional e internacional

Código Penal y Ley de Enjuiciamiento Criminal ✨

- EL CODIGO PENAL. LEY ORGÁNICA 10/1995, DE 23 DE NOVIEMBRE, del Código Penal está en constante evolución, siendo su última actualización importante en abril del 2023.
- El código Penal es de atención por dos motivos diferentes:

1.2 Marco normativo nacional e internacional

Código Penal y Ley de Enjuiciamiento Criminal

- A partir de 2015, la persona jurídica puede ser responsable plenamente de los delitos que expresamente señala el Código Penal que pueden dar lugar a su responsabilidad. Por ello es habitual que las organizaciones desarrollen sistemas de Compliance para prevenir la infracción de normas de carácter penal y evitar eventuales sanciones que generen responsabilidad a la empresa. La participación del CISO es fundamental en estos sistemas de Compliance.

1.2 Marco normativo nacional e internacional

Código Penal y Ley de Enjuiciamiento Criminal

- Propiamente por la codificación de los “delitos informáticos”, es decir, tanto aquellos en los que la infraestructura IT o la información son el objeto o bien jurídico protegido, como los delitos en los que la tecnología es el medio para su comisión (el llamado “Ciberdelito”).
- Así mismo, la Ley de Enjuiciamiento Criminal es de atención por contener en el Título VIII, Capítulo 4 y siguientes, información relevante para la obtención de evidencias y el despliegue de controles.

1.2 Marco normativo nacional e internacional

Directiva NIS (Network and Information Systems) ✨

- Garantiza un elevado nivel común de seguridad de las redes y sistemas de información en la Unión Europea.
- Condiciones de seguridad para empresas y organismos que proporcionan servicios esenciales y servicios digitales.



1.2 Marco normativo nacional e internacional

Directiva NIS2 ¿A quién afecta?

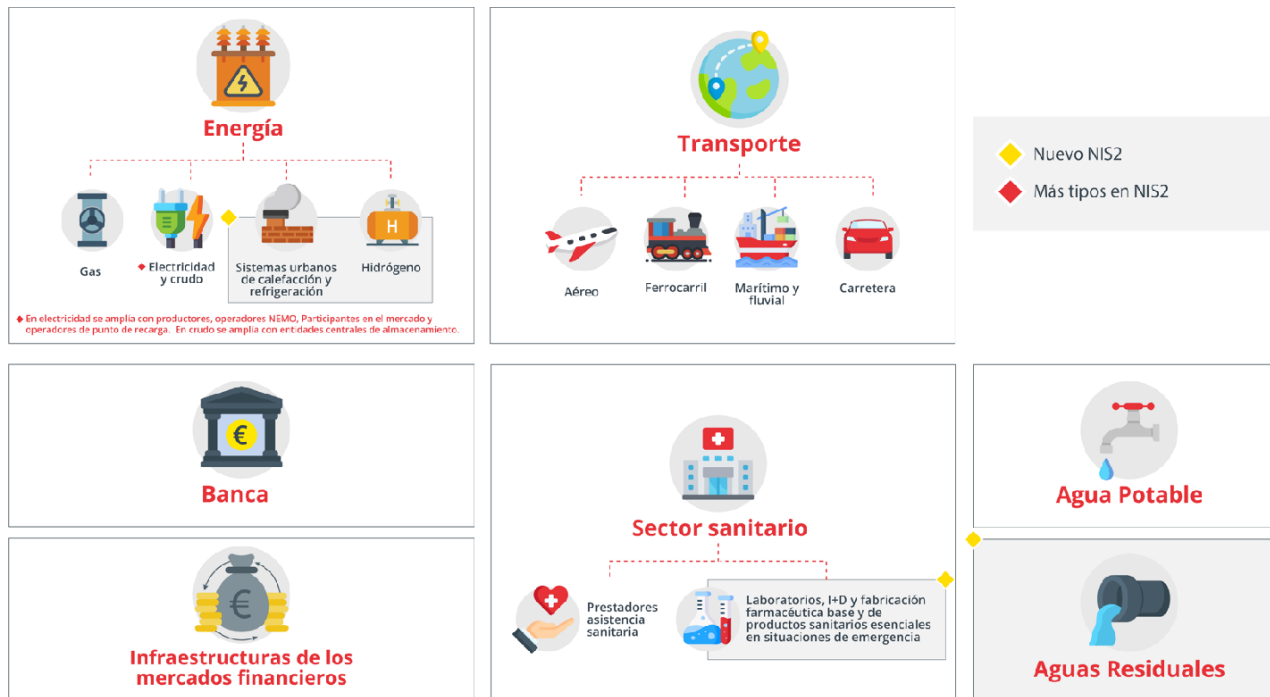
- Con carácter general, la directiva aplica a medianas y grandes empresas, ya sean públicas o privadas, de los sectores de alta criticidad y otros sectores críticos indicados en sus anexos I y II, respectivamente, que presten sus servicios o lleven a cabo sus actividades en la Unión Europea.

[Noticia](#)



Sectores en el ámbito de NIS2

Anexo I: Sectores de alta criticidad



Sectores en el ámbito de NIS2

Anexo I: Sectores de alta criticidad



Anexo 2: Otros sectores críticos



**Servicios postales
y de mensajería**



**Gestión de
residuos**



**Fabricación, producción y
distribución de sustancias
y mezclas químicas**

◆ Nuevo NIS2



**Producción,
transformación
y distribución de
alimentos**



Fabricación de:

- ◆ Productos sanitarios y diagnóstico in vitro.
- ◆ Productos informáticos, electrónicos y ópticos.
- ◆ Material eléctrico.
- ◆ Maquinaria y equipo ncop.
- ◆ Vehículos de motor, remolques y semirremolques.
- ◆ Otro material de transporte.



**Organismos
de investigación**



**Proveedores de
servicios digitales**

- ◆ Proveedores de mercados en línea.
- ◆ Motores de búsqueda en línea.
- ◆ Plataformas de RRSS.

1.2 Marco normativo nacional e internacional

Ley de Seguridad privada 📌

- Regula la realización y prestación de actividades y servicios de seguridad privada para la protección de personas y bienes e investigaciones privadas.
- En incidentes con infracciones penales, laborales, tributarias, etc. el director de seguridad efectuará la comunicación a las autoridades de control.
- En incidentes que comprometan información sensible se tomarán acciones de comunicación.
- En investigaciones, el CISO se asegurará de la legitimidad de la intervención para garantizar investigaciones legítimas.

1.2 Marco normativo nacional e internacional

Ley de Protección de Infraestructuras Críticas (LPIC) 📌

- Estrategias y estructuras para dirigir y coordinar actuaciones de las Administraciones Públicas para mejorar la prevención, preparación y respuestas a amenazas que afecten a infraestructuras críticas.
- Colaboración entre organismos gestores para proteger a la población.
- Designación de CISO y CISO suplente.
- Subordinación del CISO al Responsable de Seguridad y Enlace a la hora de relacionarse con la autoridad de control.

1.2 Marco normativo nacional e internacional

Secretos empresariales ✨

- Obligación de las empresas a salvaguardar conocimientos técnicos e información ilegal contra su obtención, utilización y revelación ilícitas.

Sector Juego ✨

- Las empresas del Sector Juego (online) se encuentran sujetas a la Ley de Regulación del Juego, al desarrollo de la misma y resoluciones técnicas relacionadas.



1.2 Marco normativo nacional e internacional

Sector Financiero -Banca

- EL REAL DECRETO-LEY 19/2018, DE 23 DE NOVIEMBRE, de servicios de pago y otras medidas urgentes en materia financiera.
- European Banking Authority (EBA), sobre la actividad en el ámbito tecnológico de las entidades. (A punto de ser sustituido por DORA (Resiliencia Operativa))
- Directrices sobre la evaluación del riesgo de TIC en el marco del proceso de revisión y evaluación supervisora
- Recomendaciones sobre la externalización de servicios a proveedores de servicios en la nube, EBA/REC/2017/03.
- Guidelines on outsourcing, publicadas por el Committee of European Banking Supervisors (CEBS), en el 2006.

1.2 Marco normativo nacional e internacional

Sector Defensa ✨

- Secretos Oficiales.
- Política de Seguridad de la Información.
- Normas de la Autoridad Nacional para la Protección de Información Clasificada.
- Normativa OTAN.
- Normativa OCCAR.
- Normativa LoL/FA EDIT, reestructuración industria europea de defensa.

1.2 Marco normativo nacional e internacional

Export Control 🌟

- Export Control Officer, responsable del cumplimiento normativo.
- Normativa US ITAR, exportación de material militar.
- Normativa US EAR, regula la exportación de material de doble uso.
- Real Decreto 679/2014, de 1 de agosto, de control del comercio exterior de material de defensa, de otro material y de productos y tecnologías de doble uso.
- Normas de Export Control en la Unión Europea.

1.2 Marco normativo nacional e internacional

Protección de datos 📌

- Relativo a la protección de las personas físicas respecto al tratamiento de datos personales y la libre circulación de estos.
- Obligado cumplimiento para las empresas cuando recopilan, guardan, tratan, o gestionan datos personales de los ciudadanos de la Unión Europea.
- Devuelve al ciudadano el control de sus datos personales.
- El incumplimiento de este acarrea sanciones significativas.